Nama : Wanda Pramudya R Matkul : Pemograman Web 2

Kelas : 1243B Dosen : Agung Nugroho, S.Kom., M.Kom.

Nim : 312410102 Tugas : Ulangan Tengah Semester

Belajar SQL Injection Lewat Percobaan Login Aplikasi Web Sederhana

Pendahuluan

Di masa sekarang, kemajuan teknologi web melaju sangat cepat dengan hampir seluruh platform digital yang terintegrasi ke basis data. Mulai dari mekanisme masuk akun, pengelolaan informasi user, sampai pada proses transaksi daring, seluruhnya bertumpu pada proteksi data yang kuat. Sayangnya, aspek keamanan sering kali kurang menjadi prioritas utama bagi sebagian pengembang aplikasi web.

Pengertian SQL Injection

Teknik eksploitasi SQL Injection terjadi saat sebuah aplikasi berbasis web memiliki kerentanan dalam menyusun perintah SQL dari data yang dimasukkan user. Tanpa adanya pengamanan yang ketat, pihak luar bisa memasukkan baris kode SQL ilegal guna memanipulasi alur logika pada query tersebut. Kerentanan semacam ini umumnya muncul pada kolom pencarian, sistem autentikasi, serta berbagai halaman yang terhubung ke basis data.

Gambaran Cara Kerja SQL Injection

Pada aplikasi login yang tidak aman, biasanya query SQL ditulis dengan cara menggabungkan input pengguna secara langsung. Contoh query yang rentan adalah sebagai berikut:

```
SELECT * FROM users
WHERE username =
'$username'
AND password = '$password';
```

Apabila variabel username dan password diambil langsung dari masukan user tanpa melalui tahap verifikasi, maka perintah query tersebut menjadi sangat rentan untuk dimanipulasi.

Eksperimen SQL Injection yang Saya Lakukan

Lingkungan Pengujian

Eksperimen ini saya lakukan menggunakan:

- Sistem Operasi: Windows
- Web Server: XAMPP
- Bahasa Pemrograman: PHP
- Database: MySQL
- Browser: Google Chrome

Saya membuat sebuah aplikasi login sederhana dengan tabel users yang berisi kolom id, username, dan password.

Pengujian Login Normal

Tahap awal dimulai dengan melakukan uji coba masuk akun memakai data yang valid, antara lain:

- Username: admin
- Password: admin123

Hasilnya, sistem berhasil login seperti yang diharapkan. Ini menandakan bahwa fungsi login berjalan normal.

Percobaan SQL Injection

Setelah itu, saya mencoba memasukkan input tidak wajar pada kolom username, yaitu:

```
' OR '1'='1
```

Kolom password dibiarkan kosong.

Melalui masukan tadi, perintah SQL yang diproses oleh aplikasi akan bertransformasi menjadi :

```
SELECT * FROM users
WHERE username = '' OR '1'='1'
AND password = '';
SELECT * FROM users
WHERE username = '' OR '1'='1'
AND password = '';
```

Karena kondisi '1'='1' selalu bernilai benar, maka sistem tetap mengembalikan data dari database. Hasilnya, akses ke dalam sistem dapat diperoleh sepenuhnya meski tanpa menggunakan informasi login yang benar.

Hasil yang Didapat

Dari percobaan tersebut, saya menyimpulkan bahwa:

- Sistem login dapat dilewati dengan sangat mudah
- Eksploitasi melalui SQL Injection memungkinkan pihak yang tidak berwenang untuk mendapatkan akses masuk ke dalam sistem secara ilegal.
- Aplikasi tanpa pengamanan input sangat berisiko digunakan

Eksperimen ini menunjukkan bahwa celah kecil dalam penulisan query dapat berdampak besar terhadap keamanan sistem.

Dampak SQL Injection

Apabila celah SQL Injection dieksploitasi pada sistem yang sedang berjalan, risiko yang ditimbulkan sangatlah fatal, seperti :

- Kebocoran data pengguna
- Perubahan atau penghapusan data penting
- Pengambilalihan akun administrator
- Kerusakan sistem dan penurunan kepercayaan pengguna

Oleh karena itu, serangan ini tidak boleh dianggap sepele.

Cara Mencegah SQL Injection

Menggunakan Prepared Statement

Penggunaan prepared statement merupakan salah satu metode paling ampuh dalam menangkal serangan SQL Injection. Melalui teknik ini, struktur perintah SQL akan dipisahkan sepenuhnya dari data yang dimasukkan oleh pengguna.

```
$stmt = $conn->prepare("SELECT * FROM users WHERE username=? AND
password=?");
$stmt->bind_param("ss", $username, $password);
$stmt->execute();
```

Melalui metode tersebut, data yang dimasukkan oleh user akan diperlakukan murni sebagai teks biasa dan tidak akan dieksekusi sebagai bagian dari instruksi SQL.

Pembatasan Hak Akses Database

Penerapan prinsip hak akses minimum sangat penting, di mana akun basis data hanya dibekali izin yang benar-benar diperlukan oleh operasional aplikasi. Hal ini bertujuan untuk meminimalkan dampak jika serangan berhasil dilakukan.

Kesimpulan

Hasil eksperimen ini menunjukkan bahwa tanpa penanganan yang tepat, SQL Injection menjadi ancaman keamanan yang sangat serius. Bahkan, sebuah sistem masuk akun yang simpel pun tetap memiliki risiko tinggi untuk dieksploitasi jika data dari user tidak diproteksi dengan benar.

Melalui penggunaan prepared statement, validasi input, dan pengaturan hak akses database, risiko SQL Injection dapat dikurangi secara signifikan. Melalui pengujian ini, saya mendapatkan wawasan yang lebih mendalam mengenai betapa krusialnya faktor keamanan saat membangun sebuah platform web.

Referensi

- OWASP Foundation – SQL Injection
- Dokumentasi PHP – Prepared Statements
- W3Schools – SQL Injection

Link Artikel :

https://www.kompasiana.com/wandapramudya1401/69edf18aed64156e55678ce3/belajar-sql-injection-lewat-percobaan-login-aplikasi-web-sederhana

wandapramudya
Karyawan
Hiking

Advertisement

KAMPUSIANA

Belajar SQL Injection Lewat Percobaan Login Aplikasi Web Sederhana

26 April 2026 18:05 | Diperbarui: 2 Mei 2026 11:55 | 27

wandapramudya
Karyawan

Hiking

KAMPUSIANA

Belajar SQL Injection Lewat Percobaan Login Aplikasi Web Sederhana

26 April 2026 18:05 | Diperbarui: 26 April 2026 18:05 | 10 0 0

Laporkan Konten